

NOAUDIT ALTER, UPDATE ON SC;

审计设置以及审计日志一般都存储在数据字典中。必须把审计开关打开,才可以在系统表 SYS_AUDITTRAIL 中查看到审计信息。

安全审计机制将特定用户或特定对象相关的操作记录到系统审计日志中,作为后续对操作的查询分析和追踪的依据。通过审计机制,可以约束用户可能的恶意操作。

4.5 数据加密

数据库的安全性归根结底是要保护数据的安全,特别是高度敏感性数据,例如财务数据、军事数据、国家机密数据等。除前面介绍的安全性措施外,还可以采用数据加密技术。数据加密是防止数据库数据在存储和传输中失密的有效手段。加密的基本思想是根据一定的算法将原始数据——明文 (plaintext) 经过一系列复杂的计算,变换为不可直接识别的格式——密文 (ciphertext),从而使不知道解密算法的人无法获知数据的内容。

数据加密主要包括存储加密和传输加密。

1. 存储加密

存储加密一般有透明和非透明两种方式。透明存储加密是内核级加密保护方式,对用户完全隐蔽;非透明存储加密则是通过多个加密函数实现的。

透明存储加密是数据在写到磁盘时对数据进行加密,授权用户读取数据时再对其进行解密。由于数据加密对用户隐蔽,即用户不知道数据是被加密的密文,数据库的应用程序不需要做任何修改,只需在创建表语句中说明需加密的字段即可。当对加密数据进行增加、删除、修改和查询操作时,数据库管理系统将自动对数据进行加密、解密工作。基于数据库内核的数据存储加密、解密方法性能较好,安全性较高。

2. 传输加密

数据库在使用过程中通过网络传输登录系统的信息、SQL 语句和数据,若采用明文方式传输,容易被网络中的恶意用户截获或篡改,存在安全隐患。为了保证这些信息能够安全地进行交换和传输,数据库管理系统提供了传输加密功能。常用的传输加密方式如链路加密和端到端加密。其中,链路加密对传输数据在链路层进行加密,它的传输信息由报头和报文两部分组成,前者是路由选择信息,后者则是传送的数据信息。这种方式对报文和报头均加密。相对地,端到端加密对传输数据在发送端加密、接收端解密。它只加密报文,不加密报头。与链路加密相比,它只在发送端和接收端需要密码设备,而中间节点不需要密码设备,因此它所需的密码设备数量相对较少。但这种方式不加密报头,从而容易被非法监听者发现并从中获取敏感信息。

图 4.5 是一种基于安全套接层协议 (secure socket layer protocol, SSL protocol) 的数据库管理系统可信传输方案。它采用的是一种端到端的传输加密方式。在这个方案中,通信双方协商建



图 4.5 基于 SSL protocol 的数据库管理系统可信传输示意图

立可信连接，一次会话采用一个密钥，传输数据在发送端加密、接收端解密，有效降低了重放攻击和恶意篡改的风险。此外，出于易用性考虑，这个方案的通信加密还对应用程序透明。它的实现思路包含以下三点。

① 确认通信双方端点的可靠性。数据库管理系统采用基于数字证书的服务器和客户端认证方式实现通信双方的可靠性确认。用户和服务器各自持有由外部数字证书认证中心 (certificate authority, CA) 或企业内建 CA 颁发的数字证书，双方在进行通信时均首先向对方提供己方证书，然后使用本地的 CA 信任列表和证书撤销列表 (certificate revocation list, CRL) 对接收到的对方证书进行验证，以确保证书的合法性和有效性，进而保证对方确系通信的端。

② 协商加密算法和密钥。确认双方端点的可靠性后，通信双方协商本次会话的加密算法与密钥。在此过程中，通信双方利用公钥基础设施 (public key infrastructure, PKI) 方式确保服务器端和客户端协商过程通信的安全可靠。

③ 可信数据传输。在加密算法和密钥协商完成后，通信双方开始进行业务数据交换。与普通通信路径不同的是，这些业务数据在被发送之前将被用某一组特定的密钥进行加密和消息摘要计算，以密文形式在网络上传输。当业务数据被接收时，需用相同的一组特定的密钥进行解密和摘要计算。所谓特定的密钥是由先前通信双方磋商决定的，为且仅为双方共享，通常称之为会话密钥。第三方即使窃取传输密文，因无会话密钥也无法识别密文信息。一旦第三方对密文进行任何篡改，就会被真实的接收方通过摘要算法识破。另外，会话密钥的生命周期仅限于本次通信，理论上每次通信所采用的会话密钥不同，因此避免了使用固定密钥而引起的密钥存储类问题。

数据加密使用已有的密码技术和算法对数据库中存储的数据和传输的数据进行保护。常见的数据加密算法可以分为对称加密算法 (如 AES 算法) 和非对称加密算法 (如 RSA 算法)。各数据库管理系统还常常自己设计和采用特定的加密算法，使加密后数据的安全性得到进一步提高。即使攻击者获取数据源文件，也很难获取原始数据。但是，数据的加密和解密过程增加了查询处理的复杂性，将使查询效率受到影响。加密数据的密钥管理和数据加密对应用程序的影响，都是数据加密过程中需要考虑和解决的问题。

4.6 其他安全性保护

为满足较高安全等级数据库管理系统的安全性保护要求,在自主存取控制和强制存取控制之外,还有推理控制以及数据库应用中的隐蔽信道和数据隐私等技术。

1. 推理控制

推理控制(inference control)处理的是强制存取控制未解决的问题。例如,利用属性之间的函数依赖关系,用户能从低安全等级信息推导出其无权访问的高安全等级信息,进而导致信息泄露。

数据库推理控制机制用来避免用户利用其能够访问的数据推知更高密级的数据,即用户利用其被允许的多次查询结果,结合相关领域背景知识以及数据之间的约束,推导出其不能访问的数据。在推理控制方面,常用的方法如基于函数依赖的推理控制和基于敏感关联的推理控制等。例如,某公司信息系统中假设姓名和职务属于低安全等级(如公开)信息,而工资属于高安全等级(如机密)信息。用户A的安全等级较低,他通过授权可以查询自己的工资、姓名、职务,及其他用户的姓名和职务。由于工资是机密信息,因此用户A不应知道其他用户的工资。但是,若用户B的职务和用户A相同,则利用函数依赖关系职务 $\rightarrow$ 工资,用户A可通过自己的工资信息(假设3000元),推出B的工资也是3000元,从而导致高安全等级的敏感信息泄露。

2. 隐蔽信道

隐蔽信道(covert channel)处理的内容也是强制存取控制未解决的问题。下面的例子就是利用未被强制存取控制的SQL语句执行后反馈的信息进行了间接信息传递。

一般情况下,如果INSERT语句对UNIQUE属性列写入重复值,则系统会报错且操作失败。那么,针对UNIQUE约束列,高安全等级用户(发送者)可先向该列插入(或不插入)数据,而低安全等级用户(接收者)后向该列插入相同数据。

如果插入失败,则表明发送者已向该列插入数据,此时二者约定发送者传输信息位为0;如果插入成功,则表明发送者未向该列插入数据,此时二者约定发送者传输信息位为1。通过这种方式,高安全等级用户按事先约定方式主动向低安全等级用户传输信息,使得信息流从高安全等级向低安全等级流动,从而导致高安全等级敏感信息泄露。

3. 数据隐私

随着人们对隐私的重视,数据隐私成为数据库应用中新的数据保护模式。

数据隐私是控制不愿被他人知道或他人不便知道的个人数据的能力。数据隐私范围很广,涉及数据管理中的数据收集、数据存储、数据发布等各个阶段。例如,在数据存储阶段应避免非授权的用户访问个人的隐私数据。通常可以使用数据库安全技术实现这一阶段的隐私保护。如使用自主访问控制、强制访问控制和基于角色的访问控制以及数据加密等。在数据处理阶段,需要考虑数据推理带来的隐私数据泄露。非授权用户可能通过分析多次查询的结